

POLICY

| ITWORKS | 169

Title

ICT User Access Control Policy

Version Approved

IT WORKS Executive

Active Date: 31 May 2021

Contact Officer

Name

Peter Perfect

(08) 8000 0000

Position Title

Manager – Service Delivery

Email Address

perfectp@itworks.com.au

Table of Contents

1	Policy.....	2
2	Scope	2
3	Definitions.....	2
4	Related policies	2
5	Procedure	2
5.1	Authorization of access.....	3
5.2	User authentication.....	3
5.3	General password standards	3
5.4	Password selection guidelines	4
5.5	Review of access.....	4
5.6	Resetting of passwords.....	4
5.7	Unauthorized access	4
5.8	Obsolete or incorrect access.....	5
5.9	Access monitoring	5
5.10	Default and guest accounts	5
5.11	Service Accounts	5
5.12	Unattended devices	5
5.13	Screen savers and locks.....	5
5.14	Privileged access.....	6
6	Responsibilities.....	6
6.1	Specific responsibility of IT WORKS staff.....	6
6.2	Review of this Policy.....	6

1 Policy

IT WORKS will implement control measures based on business owner requirements and assessed/accepted risks for controlling access to all information, ICT systems, networks, infrastructures, and applications. IT WORKS access control rules will be consistent with business requirements and information classification as well as legal obligations.

This policy supports and extends the IT WORKS Information Security Policy.

2 Scope

This policy applies to all user access to IT WORKS networked ICT systems.

3 Definitions

Privileged access	Privileged access is access that provides elevated capabilities and can allow users to take actions that affect ICT systems, network communications, or the information or accounts of other users.
Authentication	The process by which a person's identity is verified by an ICT system to which he or she is attempting to establish a connection and his or her authority to connect to that system is confirmed. In IT WORKS this is usually achieved by users supplying a password.

4 Related Policies

ITWORKS/171	IT WORKS Information Security Policy
ITWORKS/186	ICT Remote Access Security Policy
ITWORKS/170	Cyber Security Incident Reporting Policy

5 Procedure

The procedures in this policy establish controls for access to IT WORKS information and business processes that reflect business and security requirements including procedures for information dissemination and authorization.

5.1 Authorization of access

Access to an ICT system will only be granted if it has been authorized by the owner of that ICT system, or another person delegated to approve such access.

- The system access requested must be the minimum needed, consistent with the business requirement for the access. The person authorizing access must ensure this occurs.
- Acceptable use agreements must be in place for all users, including staff and students. Such agreements must be in the form of a written agreement, acknowledged by the user, outlining the terms and conditions of use of IT WORKS ICT systems and the consequences of non-compliance. Agreements must be retained and available for future reference.
- Consult the ICT Remote Access Security Procedure for additional information on requesting remote access to IT WORKS ICT systems.

5.2 User authentication

A unique user identifier will be issued to each authorized user of an ICT system, to be used in conjunction with a secret password to authenticate the user.

- When personnel are first assigned a user identifier, they are to be given an initial expired password, which must be changed at first logon to the system. Expired passwords must also be provided if personnel forget their password and it is reset.
- Personnel cannot allow others to use their user identifier and password, either deliberately or through negligence, nor must they attempt to use another person's user identifier.
- Personnel will be held accountable for all actions performed under their user identifier.
- Group or shared user identifiers will not be permitted unless authorized by the CEO.

5.3 General password standards

A password is used to verify the user's identity and therefore is the key to accessing IT WORKS ICT systems. Passwords must be kept secret and protected from compromise or disclosure to other people. Users must make certain that no one else can impersonate them on the system, as they will be held accountable for any actions performed under their user identifier.

Users must observe the following standards for their password:

- They must not divulge it to another person.
- They must not display it on or near their computer.
- They must protect passwords that are written down or stored electronically from loss, disclosure, or association with the corresponding user identifier.
- They must not code it in files, scripts, or "playback" function keys.
- They must take care that they are not being watched when typing it in.
- They must change their password regularly.
- They must change their password immediately if they suspect that it has been compromised and report it to the ICT Service Desk.
- They must choose a password that will be difficult for someone who knows them to guess.
- They must not reuse the previous password within six months.
- They must not use their IT WORKS passwords on external systems.

Persistent failure or intentional non-conformance with this policy may result in disciplinary action. The general principles embodied in these standards also apply to any form of user authentication device or method.

5.4 Password selection guidelines

To assist in selecting quality passwords that are not easy to guess, users are encouraged to observe the following guidelines:

- Select passwords that are at least eight characters long.
- Avoid using words from an English or foreign language dictionary.
- Use a mix of alphabetic and numeric or special characters.
- Avoid passwords with more than two consecutive identical characters.
- Avoid passwords containing month, year, or day.
- Avoid passwords containing their user identifier or their name.
- Avoid passwords that could be easily associated with them, such as names of family members, birth dates, addresses, or car registration.
- Avoid using strings of repeated characters or other character combinations that are easy to observe when typing in.
- Select a password that is easy to remember.
- Do not use the same password across multiple websites or services, to limit the possible harm if your password is guessed or is exposed by any website. Do not use your IT WORKS passwords on any external websites.

Where possible, IT WORKS computer systems will enforce these guidelines. Passwords for Active Directory-connected services will comply with the password policy defined in the ICT Standard Active Directory Password Policy.

5.5 Review of access

Reviews of access to applications and supporting ICT infrastructure will be performed periodically to ensure that access is limited to appropriate personnel. The frequency of the review process and the depth to which it is performed will be relevant to the specific risks associated with the information concerned. Such reviews can be initiated by ICT Services or information owners.

5.6 Resetting of passwords

To reduce the likelihood of unauthorized access to ICT systems the following considerations apply:

- Password reset processes must consider the level of verification of the requestor's identity required for a password reset. This level of verification must be based on the classification of the information and a risk assessment.
- Passwords can only be reset by a user using a secure challenge/response system, or by people approved by ICT Services and after appropriate formal identification.
- Challenge/response systems can only be deemed secure where the user enters their challenge/response into the system which stores it in a securely encrypted form.

Where a user already has access to the system (and hence their e-mail) passwords must be sent to the requestor's e-mail account.

5.7 Unauthorized access

Personnel must only attempt to access those information resources and functions of a computer system that they have been authorized to access according to their business needs. Attempting to access unauthorized resources or functions may lead to disciplinary action.

Students and non-ICT staff are not permitted to have access to IT WORKS production ICT environments, ICT-supported servers, databases (other than reporting databases/tables), or supporting infrastructure.

5.8 Obsolete or incorrect access

User identifiers and access authorities previously granted must be withdrawn on a timely basis when they are no longer required. All obsolete accounts will be deleted. Individual users and their managers or supervisors should ensure this occurs.

- When users terminate their association with IT WORKS, their former manager must request removal of their access immediately and their access must not be provided to replacement staff.
- Users must contact the ICT Service Desk immediately if they detect they have the access they should not have. Refer to the Cyber Security Incident Reporting Procedure for more information.

5.9 Access Monitoring

The usage of ICT systems is logged to manage system performance, monitor compliance with policies, or as a part of disciplinary or other investigations. Unauthorized access attempts are monitored and recorded.

5.10 Default and guest accounts

Guest account user identifiers must not be used in IT WORKS ICT systems and must be removed or disabled.

Default accounts, for example, those provided by vendors on their products, must have their default password changed to a secure complex password.

5.11 Service Accounts

Service accounts are for the specific purpose of allowing IT-related servers/services to communicate. Service Accounts are not to be used for interactive logins and their passwords are not to be shared under any circumstance.

5.12 Unattended devices

When users leave the vicinity of their workstation, whether during or after their work period, they must avoid giving other people who are not authorized to access or view confidential information on their screen or the opportunity to operate their computer session by:

- logging off the computer system when leaving the area (this must be done after the work period); or
- ensuring that the workstation is physically locked when leaving (via a key if one is fitted); or
- ensuring that the computer session is logically locked when leaving, via an approved screen saver or other means.

Password, PINS, or other available locking measures should be activated on laptop and mobile equipment for additional protection when the equipment is left unattended.

Consideration should be given to physically secure computer equipment (e.g. using cables and locks) where a risk of theft of equipment exists when the office is unattended.

While compliance with this requirement is important when the computer equipment is in IT WORKS office premises, it is even more important when using a remote access facility from home or any other location.

5.13 Screen savers and locks

If the workstation is a computer connected to the network, or a stand-alone laptop or desktop computer, then the use of an approved password-protected screen saver or workstation locking facility is mandatory,

and the standard for automatically logically locking the session is after 10 minutes of inactivity (maximum). An approved screen saver is compatible with the computer's operating system, cannot be interrupted or terminated without supplying the correct password or rebooting the computer, and has been approved for use by ICT Services.

If an approved screen saver is not being used, or if your screen saver does not have password protection activated or it is set to activate after a period greater than the minimum above, then the selection and/or setting in the desktop configuration must be changed. Contact the ICT Service Desk if you require assistance. The secrecy of the screen saver password must be protected.

It is not acceptable for users to leave the terminal with a session signed on and rely on the screen saver to automatically lock it after some time. This is a fallback protective measure only. Users must instead lock their workstations before they leave the area.

The use of software or any other service to circumvent screen savers and locks is strictly forbidden and may lead to disciplinary action.

5.14 Privileged access

The following conditions apply in managing privileged access:

- The allocation of privileged access to users must be strictly limited and controlled on a need-to-use basis. The person authorizing the access must ensure this and must retain approvals for privileged access requests as official records.
- Privileges should be allocated on an event-by-event rather than a permanent basis.
- All requests for privileged accounts are to be made via the Enterprise Service Management tool, currently MyT.
- Privileged accounts will only be approved where there is an appropriate and detailed business requirement that cannot be met through any other means.
- Privileged accounts require the approval of the Team Lead, Cyber Security and Risk as well as the Team Lead, End User Computing (or delegate) before the creation of such accounts.
- For computer systems classified as **[SLC]** Sensitive: Legal or Commercial, **[SM]** Sensitive: Medical or **[SP]** Sensitive: Personal (or above) privileged access must be assigned to a different user identifier from that used for normal use wherever possible.
- Privileged access to computer systems classified as **[SLC]** Sensitive: Legal or Commercial, **[SM]** Sensitive: Medical, or **[SP]** Sensitive: Personal (or above) must be subject to regular review by ICT Services. Verification that the privileged access continues to be required, and a record of the review, must be retained as official records.
- Approval of privileged accounts will be reviewed annually during March.

6 Responsibilities

6.1 Specific responsibility of IT WORKS staff

All IT WORKS staff are required to comply with the Information Security Policy and related policies, procedures, and standards of IT WORKS, the Code of Ethics, and to play an active role in protecting information assets.

6.2 Review of this Policy

IT WORKS Policy must be reviewed at least every two years, but may be actioned earlier according to strategic priorities, reforms, or feedback received.